

A Minimal Common Assurance Architecture for Stateful AI Systems

A Framing Proposal for Connecting Existing and Future Defensive Mechanisms

Public Technical Note — Discussion Draft v0.1 | September 2026

Status: Open for discussion and revision

Abstract

Stateful AI systems increasingly combine persistent state, tools, delegated authority, automated actions, and AI-based monitoring. Many defensive mechanisms relevant to these systems already exist, but independently developed mechanisms may become difficult to connect, compare, replace, or audit as systems grow more complex.

This note proposes a minimal common assurance architecture: a lightweight shared skeleton intended to make several relationships explicit without replacing existing security practice. The architecture separates the Target AI or Agent, Evidence Sources and Provenance, AI Auditors, Evidence Paths, shared dependencies, authorization and delegation, recovery validation, and cross-cutting human auditability.

A central principle is that multiple auditors do not necessarily provide independent evidence; meaningful independence cannot be inferred from auditor count alone and requires consideration of the provenance and shared dependencies of the Evidence Paths. The architecture also distinguishes user intent, granted authority, delegated scope, available capability, and executed action, while allowing AI components to remain internally opaque when sufficient external audit records are preserved.

The proposal is not a security standard or a claim of guaranteed protection. It is a shared starting point for asking whether making these relationships explicit can reduce integration friction and enable additional assurance capabilities over time.

1. Purpose and Position

This note proposes a minimal common assurance architecture for stateful AI systems. Here, assurance architecture means a shared structure for connecting defensive, auditing, authorization, recovery, and human-auditability mechanisms around AI systems.

The proposal is not intended to replace existing security practice, define a new security standard, or claim novelty for the individual defensive mechanisms discussed here. Authentication, authorization, access control, isolation, logging, monitoring, provenance, recovery, infrastructure security, and related mechanisms already provide essential foundations.

Could existing and future defensive mechanisms become easier to connect, inspect, extend, and reuse if several assurance relationships were made explicit within a shared architectural skeleton?

A practical motivation is to make such a skeleton available early. Defensive mechanisms can otherwise be developed independently and may later require additional effort to reconcile their interfaces, evidence assumptions, authority boundaries, recovery behavior, or audit semantics.

Framing → Connection → Possible Capabilities → Testing

The architecture is a working framing, not a finished solution. It is intended to be reused, criticized, modified, extended, simplified, replaced, or discarded according to what implementation and testing reveal.

2. A Minimal Common Skeleton

The architecture begins with an Existing Security Foundation and adds explicit assurance relationships around it. Its principal roles are:

Target AI / Agent	the operational system being observed.
Evidence Source	an observable source of information about a relevant event.
Evidence Provenance	origin, acquisition, transformation, and upstream history of evidence.
AI Auditor	an AI-based component that analyzes evidence about a Target AI or Agent.
Evidence Path	the traceable chain through which information about a target event is acquired, transformed, analyzed, and represented as evidence.
Evidence Assessment	comparison and interpretation of evidence, including dependencies and unresolved information.
Authorization and Delegation	structures through which granted authority is scoped and delegated for an AI system.
Recovery Material	information or state that may support restoration, reconstruction, or re-evaluation.
Human Auditability Layer	cross-cutting access to externally recorded system history.

Most of these terms use established vocabulary. Evidence Path is used here as local shorthand for: Target Event → Evidence Source → Evidence Provenance → AI Auditor → Evidence.

The components occupying these roles are intentionally not fixed.

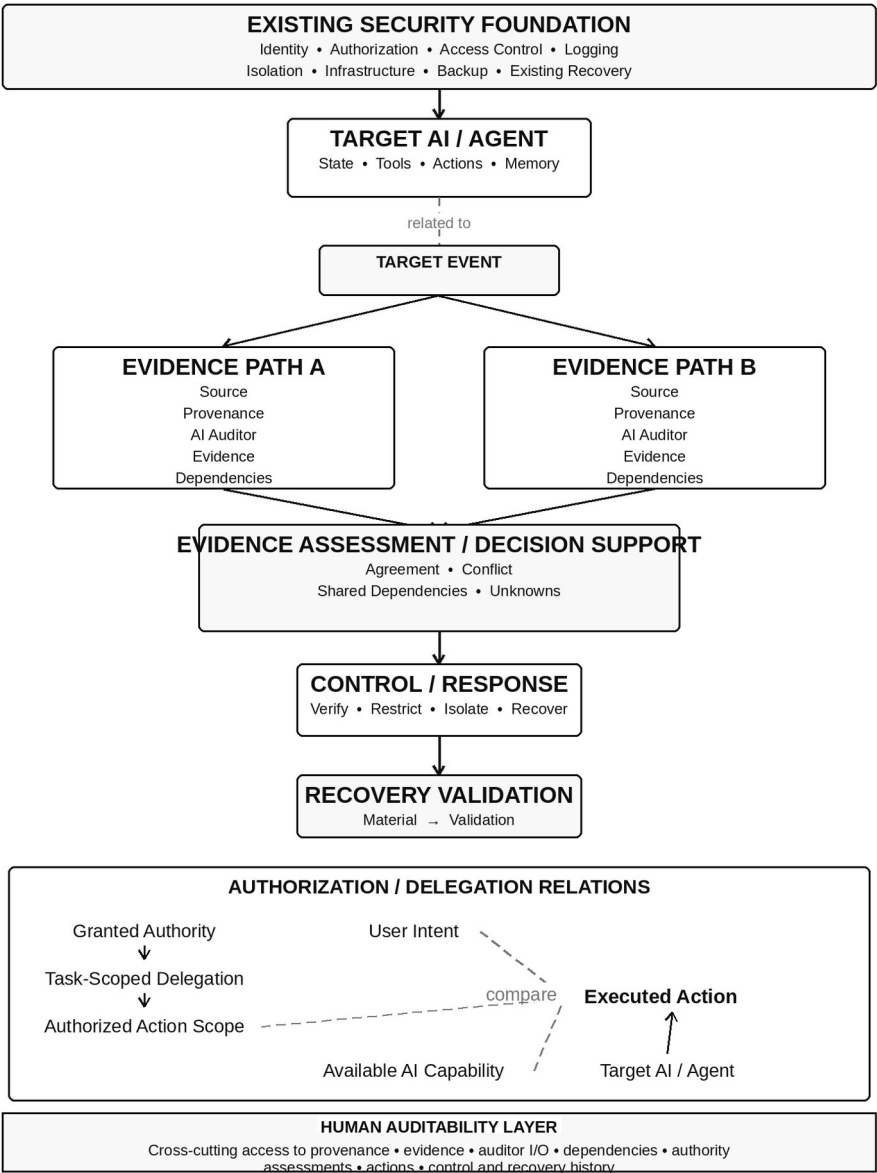


Figure 1. Minimal Common Assurance Architecture.

The two Evidence Paths are illustrative. Separate paths are not assumed to be independent; independence is assessed in light of provenance and shared dependencies. The relation between the Target AI / Agent and the Target Event indicates relevance rather than a required causal direction. Evidence Assessment supports decision-making but does not imply automatic control. Authorization, user intent, available capability, and executed action remain distinct. The Human Auditability Layer is cross-cutting and does not require human approval for every operation.

3. What Might This Framing Enable?

This is the central question of the proposal. Making the relationships above explicit does not automatically create new defensive capabilities. It may, however, make several capabilities easier to construct, combine, inspect, or evaluate.

Evidence independence analysis. Evidence Paths can be examined for shared sources, models, memory, retrieval, preprocessing, infrastructure, control mechanisms, and other dependencies.

AI-to-AI auditing. AI Auditors can be added without assuming that additional monitoring instances automatically create independent evidence.

Human incident reconstruction. Provenance and externally recorded system history may allow investigators to reconstruct relevant behavior even where individual AI components remain internally opaque.

Delegated-authority monitoring. User intent, granted authority, task-specific delegation, technical capability, and executed action can remain distinguishable.

Behavioral and privilege deviation detection. Expected and observed behavior can be compared without treating deviation itself as proof of compromise.

Recovery-path inspection. Monitoring and recovery mechanisms can be examined for common dependencies or shared possible failure paths.

Modular replacement. Evidence Sources, AI Auditors, provenance systems, and recovery mechanisms can occupy explicit architectural roles rather than forcing the entire assurance structure to be redesigned when one component changes.

Research mapping. Existing and future mechanisms can be placed against common roles and relations, making overlap, missing connections, and possible integration points easier to discuss.

Reduced integration friction. A lightweight common skeleton may reduce later effort needed to reconcile independently developed mechanisms.

These are proposed possibilities, not demonstrated guarantees.

4. Key Assurance Relationships

4.1 Evidence, Provenance, and Independence

Multiple AI Auditors do not automatically provide independent evidence. Two auditors may be separate instances while sharing the same Evidence Source, upstream generator, retrieval system, memory, model family, preprocessing, infrastructure, update mechanism, or control plane.

Multiple Auditors ≠ Independent Evidence
Evidence Agreement ≠ Independent Corroboration

Independence is therefore something to assess, not something to infer from auditor count. Evidence Provenance matters for the same reason: apparently different Evidence Sources may derive from the same upstream source or transformation process.

For this architecture, provenance primarily concerns externally observable runtime provenance: where evidence came from, how it was acquired, and how it was transformed before use. Provenance of learned internal model representations may not be recoverable at comparable resolution.

Unknown / Unresolved

Where provenance or dependency cannot be established, uncertainty should remain explicit. The architecture does not require uncertainty to be inferred away.

4.2 Black-Box AI and Human Auditability

Neither the Target AI nor an AI Auditor must expose its complete internal reasoning for this architecture to be useful. Instead, sufficient external structure should remain available around those black boxes.

Useful audit data may include event identifiers and timestamps, Evidence Sources and Provenance, auditor identity and version, relevant configuration or state, auditor inputs and outputs, reported uncertainty, shared or unresolved dependencies, authorization history, assessment results, actions, and recovery history.

The records need not be natural-language explanations. They need to remain sufficiently structured and accessible to support reconstruction of relevant externally recorded relationships such as: Event → Evidence → Assessment → Action.

AI can audit AI, while humans retain the ability to audit the assurance process.

Human auditability is therefore cross-cutting rather than a requirement for human approval of every operation.

4.3 Authorization, Delegation, Capability, and Deviation

User Intent ≠ Granted Authority ≠ Task-Scoped Delegation ≠ Available AI Capability ≠ Executed Action

A user may possess authority that was not delegated for the current task. The user's current intent may be narrower than that authority. An AI may technically possess a capability it is not authorized to exercise.

Granted Authority → Task-Scoped Delegation → Authorized Action Scope describes the authorization relation, while Available AI Capability describes what the system can technically perform. User Intent, Authorized Action Scope, and Available AI Capability can each be compared with Executed Action without treating them as equivalent or as parts of one causal chain.

This separation can expose different forms of deviation, such as actions beyond delegated scope, unexpected resource access, crossing user or tenant boundaries, unusual privilege requests, or actions inconsistent with current user intent.

Deviation ≠ Compromise

Deviation is a reason for additional verification or response, not automatic evidence of malicious behavior.

4.4 Recovery Validation

Detection does not itself provide recovery. If the current operational state may be compromised, that state should not automatically become the sole authority for restoration.

Recovery may instead use separately maintained Recovery Material, such as snapshots, provenance records, previously validated states, isolated records, or other externally maintained information. Such material is not assumed to be trustworthy merely because it is designated for recovery.

Recovery Material → Validation → Restore / Reconstruct / Re-evaluate

The assurance question is not simply whether backup exists, but whether recovery can proceed without depending exclusively on the current operational state or the same possible failure path.

5. Incremental Adoption and Possible Extensions

The architecture is intended to be incrementally deployable. A system might begin with existing security and external observability, then add structured Evidence Provenance, AI auditing, additional Evidence Paths, authorization and delegation tracking, dependency-aware assessment, and recovery validation where useful. No fixed implementation order is required, and partial adoption may still provide value.

One possible downstream use is causal analysis. If system history preserves temporal information, Evidence Provenance, dependencies, authority changes, state changes, control actions, and recovery history, interventions such as changing Evidence Sources, restricting authority, isolating components, replacing an auditor, or restoring earlier state may support causal hypothesis generation.

Temporal Order ≠ Causality

Where necessary conditions are met, the recorded structure may contribute to causal inference. Hidden state, common causes, shared dependencies, selection effects, and unobserved variables may remain. Causal analysis is therefore a potential use of the recorded structure, not a required component of the architecture.

6. Relation to Existing Work and Scope

The individual concerns represented here are not assumed to be new. Existing security and AI risk work already addresses broad areas including access control, audit and accountability, security assessment, recovery, provenance, risk management, and assurance [1–3]. Current work also addresses identity and authorization for software and AI agents [4]. Recent research has examined independence and common dependencies in AI-based auditing [5].

This note does not attempt to replace or subsume those bodies of work, nor does it claim their underlying concepts as elements of a new taxonomy. Nor does it adopt any one existing framework, taxonomy, or audit model as its organizing structure.

The cited works provide terminology and external context; they do not define the structure of the proposed architecture.

Make several relations among existing and future defensive mechanisms explicit within a small shared architecture, then test whether that structure makes them easier to connect, inspect, replace, and extend.

Established terminology is used where it adequately preserves the intended distinction. Local terminology is introduced only where necessary.

The examples throughout this note are illustrative rather than exhaustive or prescriptive. They are not mandatory components, preferred implementations, or sufficient security guarantees. Existing and future techniques may occupy the same architectural roles. Some proposed roles may prove unnecessary; additional roles may become necessary.

Accordingly, the central evaluation question remains: Does making these relationships explicit help connect existing and future defensive mechanisms into a more inspectable, extensible, and reusable assurance structure?

7. Closing Proposal

Keep existing security as the foundation. Make Evidence Sources, Evidence Provenance, AI Auditors, Evidence Paths, shared dependencies, authorization and delegation, recovery validation, and human auditability explicit. Make the shared skeleton available early enough that independently developed defensive mechanisms do not always need to be integrated from scratch later. Then test what becomes easier to connect.

Propose the skeleton → Connect existing pieces → Explore what becomes possible → Test whether the framing helps

This is not presented as a final architecture. It is a shared starting point intended to be tested, corrected, extended, simplified, or discarded.

References

- [1] E. Tabassi, Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, National Institute of Standards and Technology, 2023. doi:10.6028/NIST.AI.100-1.
- [2] Joint Task Force, Security and Privacy Controls for Information Systems and Organizations, NIST SP 800-53 Rev. 5, National Institute of Standards and Technology, 2020; Release 5.2.0, August 2025. doi:10.6028/NIST.SP.800-53r5.
- [3] National Institute of Standards and Technology, CSRC Glossary: Provenance, <https://csrc.nist.gov/glossary/term/provenance> (accessed September 30, 2026).
- [4] National Cybersecurity Center of Excellence, Accelerating the Adoption of Software and AI Agent Identity and Authorization Concept Paper, Draft, National Institute of Standards and Technology, February 5, 2026.
- [5] M. C. Ghanem, “Who Audits Whom, on What Substrate, with What Evidence? An Independence-Graded Audit Protocol for Agentic AI,” arXiv:2609.18272, September 2026.